

TM INFORMATION SECURITY ANNEX (TM ISA)

This TM Information Security Annex document (TM ISA) sets out the minimum security standard of TM Technology Services Sdn Bhd or subsidiaries under Telekom Malaysia Berhad (collectively referred to as TM)

This document consist of the following parts:

- (a) Part I General Applicability,
- (b) Part II - Applicability of Specific Sections, and
- (c) Part III – Definition and Abbreviation.

PART I GENERAL APPLICABILITY

1. General Principles

- 1.1 In addition to the general obligations on security requirements as agreed by the Supplier under the Agreement, this ISA shall apply throughout the duration of the Agreement, regardless of whether the Deliverables are procured, supplied, provided and/or performed directly by the Supplier or indirectly via third party distributors.
- 1.2 The measures under this ISA cover different aspects of information security. The extent of its applicability is dependent on the nature of the Deliverables and the scope of work as provided under the Agreement.
- 1.3 The measures prescribed under this ISA may be enforced with additional security measures which will be provided by TM and agreed between the Parties in documents which will be read together as part of the Agreement.

2. Priority Of Documents

- 2.1 The Agreement shall prevail over the ISA, unless stated otherwise or a different order of precedence has been set out in the Agreement
- 2.2 However, this ISA shall prevail over Supplier's documents defining security measures attached to or referenced in the Agreement,; and
- 2.3 All terms written in capital letters shall be interpreted according to the definitions as specified in this ISA.

3. General Applicability Of ISA

- 3.1 The Supplier shall comply with the requirements as stated in this ISA for all Deliverables that relate to the following scope of work or deliverables under the Agreement:
 - (i) Software including Software Result;
 - (ii) Hardware;
 - (iii) XaaS/Cloud Services; and
 - (iv) Professional Services.

4. Timeline

Whenever any action is to be performed, undertaken, completed or delivered under this ISA, Supplier shall comply with the timeline stipulated in the Agreement, or in this ISA or if not stated anywhere, as soon as practicable, failing which may constitute a material breach of the Agreement which will entitle TM to terminate the Agreement.

PART II

GENERAL APPLICABILITY OF SPECIFIC SECTIONS

5. Part II consist of the following sections:

5.1 List of sections in Part II

Section A	Contractual and standards compliance
Section B	Security organization
Section C	Incident management
Section D	Cryptography and authentication
Section E	Security by design
Section F	Privacy by design
Section G	Software Vulnerabilities fixing
Section H	TM Data in XaaS/Cloud Services
Section I	Access control of XaaS/Cloud Services
Section J	Operations of XaaS/Cloud Services
Section K	Access to and use of TM systems and resources
Section L	Professionals and security

5.2 Applicability of Part II sections to the type of Deliverables

SECTIONS	TYPE OF DELIVERABLES
A	All types
B	All types
C	All types
D	Software, Hardware, XaaS/Cloud Services
E	Software, Hardware, XaaS/Cloud Services
F	All types
G	Software, Hardware, XaaS/Cloud Services
H	XaaS/Cloud Services
I	XaaS/Cloud Services
J	XaaS/Cloud Services
K	Professional Services
L	Professional Services

Table A: Applicability of ISA sections

5.3 Sections

A CONTRACTUAL AND STANDARDS COMPLIANCE

A.1 Security assessment of Deliverables

Upon written request by TM, the Supplier shall provide TM within ten (10) working days all necessary information to enable TM to assess the security of Deliverables such as but not limited to security test audit reports, vulnerability scans, secure code review and code robustness analyses.

A.2 Security policies

- (1) The Supplier shall ensure that its enterprise information security policy adopts the best practices under the ISO/IEC 27001 standard or similar industry-recognized practice, such as SOC1 and SOC2 for SaaS providers.
- (2) If the Supplier is certified, the Supplier shall provide TM with a copy of the security certification and keep TM informed of renewals or revocations of the certificates.
- (3) If the Supplier was selected by TM based on a certification (e.g. ISO/IEC 27001), the Supplier shall maintain such certification during the entire contractual period of the Agreement.

A.3 Audit

TM shall have the right to undertake audits to check the Supplier's compliance with TM's security requirements as provided in the Agreement and this ISA.

A.4 Third Parties

Where the Supplier uses third parties in providing the Deliverables to TM, the Supplier shall ensure that such third parties meet the security measures agreed in the Agreement and this ISA.

A.5 Network Equipment Security Assurance Scheme (NESAS) Compliance

- (1) This section A.5 is only applicable to mobile network equipment (meaning equipment for mobile core network, radio access network (RAN) and mobile access).
- (2) The Suppliers that offer mobile network equipment must undergo the Network Equipment Security Assurance Scheme (NESAS) vendor development and lifecycle processes assessment, as defined in the respective NESAS specifications, issued by the GSM Association (GSMA PRD FS.13/15/16), in the current version.
- (3) The summary audit report that was produced as a result of the evaluation and completed by a certified auditor must also be provided to TM by the Supplier.
- (4) The assessment must be completed prior to offering any mobile network equipment.

A.6 Failure to comply with this ISA

- (1) Where the Supplier becomes aware of any non-compliance with security measures in relation to its Deliverables, the Supplier shall promptly provide TM with an analysis of the situation and a remediation plan.
- (2) If the remediation plan is accepted by TM, it will be implemented by the Supplier at no cost to TM and the Supplier shall provide TM with proof of the remediation plan's effectiveness.
- (3) If non-compliance persists or such remediation plan is not accepted by TM or fails, this will constitute a material breach of the Agreement which will entitle TM to terminate the Agreement.

B SECURITY ORGANIZATION

B.1 Structure

Upon request of TM, the Supplier shall provide information on its organization's security structure, policy and/or undertakings and requirements.

B.2 Point of contact

The Supplier shall nominate both a contact person for security related matters and an upper-management contact or key-account manager to handle all matters escalated by TM to the Supplier. The contacts shall be provided for each Deliverables and any changes to the person in charge shall be communicated promptly.

B.3 Security reviews

Annually and upon request of either Party, both Parties shall organize a meeting to review security aspects (e.g. evolutions and scheduled operations that may impact security). However, either Party may request for and conduct an exceptional security meeting at any time, upon which the other Party shall participate promptly and cooperate fully where the situation requires a common analysis or immediate decision (for example a major incident or a significant evolution of threats).

B.4 Security measure for TM data

- (1) TM data includes TM's propriety business information (such as but not limited to contracts or business plans) or technical information (such as network diagrams, credentials, or secret keys).
- (2) The Supplier shall implement the following measures to any of TM data shared with the Supplier which is classified as confidential by TM, i.e. data encrypted by TM and/or marked as Confidential:
 - (i) encrypt TM data whenever the same is stored and/or transmitted; and
 - (ii) implement a strong authentication system (e.g. two-factor authentication system).

- (3) The Parties shall agree in advance on a method of exchange in the event there is a need to exchange encrypted information.

C INCIDENT MANAGEMENT

C.1 Detection

The Supplier shall have measures in place to detect security incidents impacting TM and occurring in the Supplier's environment. Security incidents include but are not limited to loss, alteration, disclosure or unauthorized access to TM data, TM's customer data or information and unauthorized disclosure of proprietary source code.

C.2 Notification

- (1) The Supplier shall promptly notify TM in case of any such security incident.
- (2) Where breach and/or misappropriation of TM's data, TM's customer data or information is identified, the Supplier shall notify TM immediately or promptly in accordance with applicable laws or as agreed in the Agreement (whichever is the earlier) from the time the Supplier becomes aware of, or ought to have been aware of, such breach and/or misappropriation.
- (3) Details and root cause analysis of security incidents shall be provided by the Supplier within forty eight (48) hours from the time the Supplier becomes aware of, or ought to have been aware of, such breach and/or misappropriation and shall cooperate with authorities and 3rd parties identified by TM for compromise assessment.

C.3 Escalation and Resolution

- (1) The Supplier shall respond and resolve security incidents whether through its own or upon escalation from TM, and inform TM of the progress and end-of-incident based on security incident resolution service level agreement of the following table B:

Priority Level	Acknowledgement Time	Resolution Time	Update Frequency	Root Cause Analysis Report Submission to TM
P1 (Critical)	15 minutes	4 hours	1 hour	10 calendar days
P2 (High)	30 minutes	8 hours	1 hour	10 calendar days
P3 (Major)	1 hour	24 hours	4 hours	10 calendar days
P4 (Minor)	1 hour	72 hours	8 hours	10 calendar days

Table B: Security Incident Resolution Service Level Agreement

- (2) If the Supplier fails to respond and resolve within such timeline as may be stipulated in the Agreement or, if no such timeline is provided in the Agreement, as per the Table B, the liquidated damages shall be calculated following the formula as stated in section G.8.

C.4 Suspension of Supplier access to TM systems

- (1) This section C.4 is applicable to Professional Services.
- (2) In the event of a security incident resulting from the performance or the execution of Professional Services, TM may suspend Supplier from further accessing to TM systems until the incident is resolved.

C.5 Suspension of TM access to XaaS/Cloud Services

- (1) This section C.5 is only applicable to XaaS/Cloud Services.
- (2) In the event of a security incident affecting the XaaS/Cloud Services (e.g. system intrusion, malware incident), TM may suspend its own access to the said Service until the incident is resolved.
- (3) In the event where TM is not able to suspend its own access, TM shall explicitly request the Supplier to suspend all TM access until the incident is resolved. Supplier shall promptly comply with such request.

C.6 Security report for XaaS/Cloud Services and Professional Services

- (1) This section C.6 is only applicable to XaaS/Cloud Services and Professional Services.
- (2) TM may request from the Supplier a security report related to the XaaS/Cloud Services and/or Professional Services not more than twice a year. This security report shall include but is not limited to the following information:
 - (i) the number of security incidents detected over the last twelve (12) months, highlighting both internal and external causes if relevant; and
 - (ii) details of security incidents over the period (detection time, nature and impact, resolution, service recovery time, closing time, time for resolution).

D CRYPTOGRAPHY AND AUTHENTICATION

D.1 Modification of authentication data and cryptographic keys by TM

- (1) All authentication data and cryptographic keys (e.g. certificates, key pairs, symmetric keys, passwords) in Software and Hardware Deliverables shall be modifiable by TM and protected according to state-of-art.

- (2) For authentication data and cryptographic keys that are not modifiable by TM, Supplier shall provide a list of such data and their purpose to TM. For XaaS/Cloud Services, this requirement applies only to authentication data used by TM for protecting its data including administrative accounts.

D.2 Strength of cryptographic algorithms and keys

The Supplier shall implement only standardised cryptographic algorithms recommended by governmental institutions (such as NACSA and NIST) enforceable at the time when the Agreement is agreed or renewed.

E SECURITY BY DESIGN

E.1 Hardening

- (1) The Supplier shall employ system hardening best practices in compliance with TM's hardening requirements and guidelines. This includes restricting protocol access, removing or disabling unnecessary software, network ports and services, removing unnecessary files, user accounts, restricting file permissions, patch management and logging.
- (2) The Supplier shall provide Deliverables (including third party components and services) that are securely configured by default according to state-of-the-art security configuration practices (such as the configuration practice prescribed under <https://www.cisecurity.org/>).
- (3) Notwithstanding the above, the Supplier shall provide TM with all necessary information to securely configure and use Deliverables and shall ensure that such information is always up-to-date during the duration of the Agreement.
- (4) In addition, the Supplier shall ensure that Deliverables do not contain any Back Doors.

E.2 Testing for software security errors

The Supplier shall test the Deliverables to ensure that they are free of dangerous software errors listed in “**CWE/SANS Top 25**” (<http://cwe.mitre.org>) and “**OWASP TOP 10**” (<http://www.owasp.org>) at the delivery date (e.g. robustness against unexpected inputs such as SQL Injection, predictable behaviour in overload situations, etc.).

E.3 Least privilege

The Deliverables shall apply principles of least privilege and provide granular user access controls based on roles (RBAC), attribute (ABAC) and permission (PBAC)¹ on access and modifications to TM data and TM's customer data.

¹ Note:

- RBAC : Role-Based Access Control
- ABAC : Attribute-Based Access Control
- PBAC : Permission-Based Access Control

E.4 Multi-factor Authentication (MFA)

- (1) The Deliverables shall apply MFA by default for all admin and user access controls.
- (2) The Deliverables shall integrate with TM's Single-Sign-On Identity Provider enabled with Multi-Factor-Authentication using Security Assertion Markup Language (SAML) 2.0 protocol for all users' accesses (admin, normal user, reseller, sales agent, developer, third-party, etc.).

E.5 Remote Access

- (1) The Supplier shall apply secure remote access for system administration of TM assets. (e.g SSLVPN, Jumhost and SASE²).
- (2) Any system administrative role access from outside Malaysia, shall be declared and shall require express written approval from TM.

E.6 Asset and Software Inventory

- (1) The Supplier shall document and declare comprehensive bill of material and software for TM's inventory.
- (2) The Supplier shall ensure the supplied material and software shall be free of known security vulnerabilities.

E.7 NTP and DNS

The Supplier shall configure NTP synchronization and DNS resolution on all the application servers and devices using TM NTP/DNS Servers or authorized NTP/DNS servers.

E.8 Standard Operating System

- (1) A standard operating system (OS) is defined as operating systems with the following criteria:
 - (i) Fully compatible with TM's existing infrastructure, applications and security controls,
 - (ii) Well-supported by the OS vendor with large community of developers,
 - (iii) Having strong technical support, security track record and regularly updated with improvements, new features, security updates and security patches, and
 - (iv) Availability of enterprise support from the OS vendor with extended support options.
- (2) The Supplier shall deploy all applications, services and/or infrastructure component on standard operating systems.

² SASE: Secure Access Secure Edge

- (3) Any use of non-standard operating system shall be with strong justification with exception for virtual appliances.

E.9 Additional measures

- (1) Upon request from TM, the Parties shall discuss and mutually agree on additional security measures that any or all of the Deliverables must satisfy.
- (2) These additional measures shall be compiled in a document called "Security Statement of Compliance" and be included as part of the Agreement.

F. PRIVACY BY DESIGN

F.1 Data minimization

The Supplier shall ensure that any Personally Identifiable Information (PII) required are minimized and on need to know basis.

F.2 Data protection

Supplier shall ensure that PII data contained in Deliverables are hidden by use of masking, de-identified algorithm, encrypted or equivalent, while in transit, at rest and during processing. The processing of PII shall be undertaken in a distributed fashion whenever possible.

F.3 Additional measures

- (1) Upon request from TM, the Parties shall discuss and mutually agree on additional privacy measures that any or all of the Deliverables must satisfy.
- (2) These additional measures shall be compiled in a document called "Privacy Statement of Compliance" and be included as part of the Agreement

G SOFTWARE VULNERABILITIES FIXING

G.1 Detection

The Supplier shall provide measures to track third party code dependencies and to continuously monitor external security advisory sources (such as cooperative security tests, external security research, open source and third party vulnerability disclosure, etc.) and mitigate Vulnerabilities that could impact the Deliverables (including third party components). Upon request from TM, the Supplier shall provide TM within ten (10) working days all necessary information to review these measures.

G.2 Vulnerability Management

Each vulnerability detected by the Supplier shall have a unique identifier (e.g. CVE identifier associated with a CVSS score (v3 or higher) consisting of the CVSS base, the temporal score and the vector ID.)

G.3 Notifications

- (1) The Supplier shall promptly provide information to TM about each Vulnerability (with CVSS score greater or equal than 7.0) including Zero-Day impacting the Deliverables and its consequences (e.g. CVE if exists, CVSS score, affected components or services).
- (2) The Supplier shall communicate security advisories in cvrf/xml or any other parsable format via email to “GROUP INFORMATION SECURITY TM”

G.4 Service level agreement to fix Vulnerabilities

- (1) For each Vulnerability impacting the Deliverables, the Supplier shall:
 - (i) make all efforts to provide a Temporary Fix to TM according to the timeline as stipulated in the Agreement, or if no such timeline is stipulated in the Agreement, according to the following table C; and
 - (ii) make the Official Fix available to TM according to the timeline as stipulated in the Agreement, or if no such timeline is stipulated in the Agreement, according to the following table C.

CVSS base score v3	Maximum time to provide TM with a Temporary Fix ³	Maximum time to provide TM with the Official Fix
9.0-10.0 (Critical)	72 hours	14 calendar days
7.0-8.9 (High)	72 hours	30 calendar days
4.0-6.9 (Medium)	7 calendar days	60 calendar days
0.1-3.9 (Low)	30 calendar days	90 calendar days

Table C: Vulnerability Fixing Service Level Agreement

- (2) The time referred to in Table C commences upon detection of the Vulnerability, except for a Vulnerability located on third party components where the time commences upon availability of a fix.

G.5 Security maintenance of third party components

The Supplier shall ensure that third party components used within the Deliverables are security maintained during service or maintenance period as stipulated in the Agreement.

³ Temporary Fix includes by not limited to termination/isolation of vulnerable service, applying configuration changes, enforcing stricter network firewall policy, applying blocking signature at web application firewall and endpoint policies.

G.6 Vulnerability Remediation

- (1) The Supplier shall fix vulnerability impacting the deliverables during the contract period of the Agreement upon discovery or upon request by TM.
- (2) Timeline to fix such vulnerabilities shall be as detailed out in Section G.4.

G.7 Exceptions

- (1) The Supplier shall employ commercially reasonable efforts to support TM to fix Vulnerabilities:
 - (i) in occasions requiring a faster response than the Agreement, or if no such timeline is stipulated in the Agreement, following the above table C (e.g. press publication of Vulnerability in a Deliverable used by TM); and
 - (ii) in the technical environment necessary to operate the Deliverables (e.g. operating system for a Software Deliverable).

G.8 Liquidated Damages for Vulnerability fixes and Security Incident Resolution

- (1) In addition to the remedies as a consequence of a material breach as set out in section A.6, in the event of failure to comply with this ISA, TM may apply liquidated damages to the Supplier as per the sections "Liquidated Damages" of the Agreement.
- (2) In case of Vulnerabilities or Security Incident resolution, the following liquidated damages scheme shall apply:

If the Supplier fails to provide a security Temporary Fix and Official Fix for Vulnerabilities or to resolve Security Incident within such timeline as may be stipulated in the Agreement or, if no such timeline is provided in the Agreement, as per the table defined in section G.4, the liquidated damages shall be calculated as follows:

$$A = V \times N / 240$$

A: amount of liquidated damages.

V: V is the value of the Deliverables.

N: number of calendar days exceeding the Temporary Fix and Official Fix or Security Incident Resolution deadline.

G.9 Security-related maintenance

- (1) During the maintenance and/or warranty period under the Agreement, the Supplier shall provide to TM the following:
 - (i) Software and Hardware Deliverables and future releases with all security fixes.
 - (ii) security fixes as and when they are released, respecting the Vulnerability fix times as stipulated in the Agreement or, if no such timeline is provided in the Agreement, as defined in section G.4.

- (2) The Supplier shall provide information (e.g. CVE, CVSS score) to TM on the Vulnerabilities that have been fixed.

H TM DATA IN XAAS/CLOUD SERVICES

H.1 Limitation of use of TM data

The Supplier shall use TM data transmitted, processed, generated and/or stored in the XaaS/Cloud Service only to provide the said Service.

H.2 Segregation of TM data

The Supplier shall enforce segregation of TM data from data of Supplier's other customers..

H.3 TM confidential data

The Supplier shall encrypt all data that is classified by TM as confidential and stored in Supplier's XaaS/Cloud Service in/during transit and in storage.

H.4 Supplier encryption mechanisms

Where TM uses an encryption mechanism provided by the Supplier to protect TM data and TM's customer data, the Supplier shall ensure that:

- (i) such data shall be kept encrypted when stored and transmitted; and
- (ii) a strong authentication (e.g. two-factor authentication) is used for access to such data.

H.5 Logging of TM data access and use

- (1) The Supplier shall:
 - (i) log access to and usage of TM data and TM's customer data in the XaaS/Cloud Service, including by its employees and any appointed third parties; and
 - (ii) category of logs includes access logs, business event logs and audit logs for security threat and fraud monitoring and detection.
 - (iii) real-time logs are required for monitoring of security threat and fraud, by integration to TM's SIEM, analytics console or equivalent.
 - (iv) retain such logs for the duration as agreed in the Agreement including associated documents (e.g. Non-Disclosure Agreement or Data Processing Agreement), or six (6) months by default.
- (2) Extracts of retained logs shall be provided to TM on request.

H.6 TM Data reversibility

- (1) Upon termination of the Agreement, the Supplier shall make available to TM for retrieval, all TM data in the XaaS/Cloud Service in an agreed format and for a period of time mutually agreed beforehand with TM ("Data Reversibility Period").
- (2) As per sections D.2 and H.4, only encrypted connections shall be used for TM retrieval of data unless exception is given and agreed in writing by TM.
- (3) At the end of the Data Reversibility Period, the Supplier shall promptly proceed with a secure wipe in the XaaS/Cloud Service in order to irreversibly destroy TM environments and TM data. .
- (4) The Supplier shall provide TM with a certification of destruction within a timeline as agreed in the Agreement, or if not stipulated anywhere, within thirty (30) days from the end of Data Reversibility Period.

H.7 API Security

Any API implementation shall comply with API security guidelines as per TM GIS Web, Mobile and API application security Guideline, to ensure that they are free of dangerous API errors listed in "OWASP API SECURITY TOP 10" (<https://owasp.org/www-project-api-security/>) at the delivery date.

I ACCESS CONTROL OF XAAS/CLOUD SERVICES

I.1 Physical security

- (1) The Supplier shall provide physically secured facilities for both production cloud infrastructure and locations for remote operations.
- (2) Controls shall include at least:
 - (i) physical access with prior authorization and is consistently monitored;
 - (ii) everyone must visibly wear official identification while onsite;
 - (iii) visitors must sign a visitor's register and be escorted and/or observed when on the premises; and
 - (iv) possession of keys/access cards and the ability to access the locations is monitored. Staff leaving Supplier employment must return keys/cards.

I.2 System access control and password management

- (1) The Supplier shall control the Service systems by restricting access to only authorized personnel.

- (2) The Supplier shall enforce password policies on infrastructure components and cloud management systems used to operate the Supplier Service environment. The Supplier shall protect passwords using secure mechanisms such as digital vault.
- (3) The Supplier shall implement system access control, and accounting designed to ensure that only approved operations and support employees have access to the systems. System access control shall include system authentication, authorization, access approval, provisioning, and revocation for employees and any other Supplier-defined 'users'.

I.3 Review of access rights

- (1) Network and operating system accounts for Supplier employees shall be reviewed regularly to ensure appropriate employee access levels.
- (2) In the event of Supplier employee's leaving the project under the Agreement, the Supplier shall take prompt actions to terminate network, telephony, and physical access for such employees.

I.4 Security Gateway

- (1) The Supplier shall utilize security gateways (e.g. firewalls, routers, proxies, reverse proxies) to control access between the internet and Supplier Services by allowing only authorized traffic.
- (2) Supplier managed security gateways shall be deployed to perform packet inspection with security policies configured to filter packets based on protocol, port, source, and destination IP address, as appropriate, in order to identify authorized sources, destinations, and traffic types.

I.5 Anti-malware controls

The Supplier shall employ anti-malware software, including XDR, to scan uploaded files and detect anomalous file behaviours. Malware definitions shall be updated at least daily.

I.6 Encryption and remote connections to XaaS/Cloud Services

- (1) For TM access to and use of a XaaS/Cloud Service, only encrypted connections must be used unless exception has been agreed in writing by TM.
- (2) The Supplier shall ensure that only authenticated and encrypted connections are used for third parties acting on behalf of the Supplier accessing remotely TM data processed and/or stored in a XaaS/Cloud Service.
- (3) In all cases, the latest available browsers must be supported for connecting to XaaS/Cloud Services.

J OPERATIONS OF XAAS/CLOUD SERVICES

J.1 Penetration tests

- (1) The Supplier shall assess the security of the XaaS/Cloud Service using penetration tests at least on a yearly basis. The report and mitigation plan of such tests shall be shared with TM.
- (2) Notwithstanding the above, the Supplier shall allow TM to make XaaS/Cloud Service penetration tests on its production environment.

J.2 Production data and environments

- (1) The Supplier shall not use production data for testing activities.
- (2) The Supplier shall separate development, testing and production environments (e.g. networks, data, applications, etc.).

J.3 Disaster recovery plan

- (1) The Supplier shall set up and maintain a disaster recovery plan and ensure that it is tested at regular intervals, at least annually.
- (2) Backups will be securely deleted by the Supplier upon disposal.

J.4 Security-related maintenance

For any security patch that the Supplier intends to deploy on the XaaS/Cloud Service, the Supplier shall apply and test the security patch on a testing environment. Only after successful completion of testing on such environment, the Supplier will deploy the patch on the production environment.

J.5 Third Party services

The Supplier shall inform TM if third party services (e.g. data center services) are involved or planned to be involved in the provision of the service.

J.6 Relocation of data

The Supplier shall inform TM if TM data is to be relocated to another data center (including backups) other than the data center as agreed in the Agreement.

K ACCESS TO AND USE OF TM SYSTEMS AND RESOURCES

This section K will be applicable only if TM grants the Supplier access to and use of TM systems for the performance of the Agreement.

K.1 Physical

If TM provides access and/or interconnection equipment installed on Supplier premises, the Supplier shall ensure that:

- (1) physical access control is applied to the technical area where such equipment is located; and

- (2) physical access to such equipment is limited to those who need to access the equipment for the performance of the Agreement and duly authorised by the Supplier.

K.2 TM Systems

- (1) The Supplier shall:
 - (i) access and use TM's systems only to provide the Deliverables;
 - (ii) ensure that access and data transfer are not used to perform an attack (e.g. for data transfer, check for malware);
 - (iii) comply with the means of access and rules defined by TM and provided to the Supplier beforehand (e.g. respect network addresses assigned by TM, respect TM responsive times for TM management Resources, etc.);
 - (iv) ensure that anybody acting on behalf of the Supplier who needs to use TM systems is duly authorised by the Supplier and identification information has been provided to TM beforehand; and
 - (v) ensure that only duly authorised Supplier Resources are connected with TM systems.

K.3 Supplier Resources

- (1) If Supplier Resources are used to access and/or interconnect with TM systems, the Supplier shall:
 - (i) follow security best practices on management of such Supplier Resources (e.g. keep such Supplier Resources up-to-date with the latest security patches such as anti-malware software and operating systems patches and installed software, configure restricted privileges for users, configure restricted execution rights on removable media, implement mechanisms for session-locking on such Supplier Resources after a short period of inactivity, etc.);
 - (ii) ensure the Supplier Resources (including authentication tokens, mobile devices and the phone numbers associated) are dedicated to the Supplier and only used by its employees and any third parties appointed to provide the Deliverables);
 - (iii) implement network access control on the Supplier Resources used for the performance of Services;
 - (iv) implement a strong authentication system (e.g. two-factor authentication) for access to such Supplier Resources; and ensure traceability of usage of such Supplier Resources by all users;
 - (v) retain logs for the duration as agreed in Agreement including associated documents (e.g. Non-Disclosure Agreement or Data Processing Agreement), or 6 months by default; and
 - (vi) provide to TM upon request, extracts of retained logs.

- (2) If TM provides accounts to the Supplier, the Supplier shall:
 - (i) ensure traceability of account attribution and use;
 - (ii) retain traces for the duration as agreed in Agreement including associated documents (e.g. Non-Disclosure Agreement or Data Processing Agreement), or 6 months by default; and
 - (iii) provide to TM upon request, extracts of retained traces.

K.4 TM systems and applications

- (1) If TM provides accounts to the Supplier, the Supplier shall:
 - (i) promptly notify TM when an account is no longer required; and
 - (ii) ensure that accounts provided for server communications are used only for that purpose.

K.5 Management of TM Resources

If TM provides TM Resources (software, hardware, computers, USB stick, badge, tablet, smartphone, access or interconnection equipment, etc.) to the Supplier, the Supplier shall keep track of such TM Resources. Upon termination of the Agreement, the Supplier shall return TM Resources still in its possession.

L PROFESSIONALS AND SECURITY

L.1 Awareness training and education

- (1) The Supplier shall ensure that its employees and any third parties appointed to provide the Deliverables:
 - (i) possess appropriate security skills (e.g. to manage security incidents); and
 - (ii) are familiar with the content and the implementation of applicable security rules.

L.2 TM specific security rules

If TM provides specific security rules for performing the Professional Services, the Supplier shall ensure that its employees and any appointed third parties are informed of such rules before the start of any tasks.

L.3 Subcontractors

Where the Supplier uses subcontractors to fulfil the security obligations under the Agreement with TM, the Supplier shall specifically identify them as subcontractors and ensure that the same standard of care will be imposed on the subcontractors.

L.4 Handling of sensitive Deliverables

The Supplier shall use only security checked personnel, i.e. screened by national authorities, for handling of sensitive Deliverables prior to deployment in TM Network, as well as for maintenance of sensitive Deliverables during the Agreement period.

PART III DEFINITIONS AND ABBREVIATIONS

Agreement	means any contract signed by TM with the Supplier, including any purchase order issued by TM to the Supplier containing the reference to this ISA.
Assets	encompass primary and supporting assets as defined in ISO/IEC 27005.
Back Door	means a feature or defect of Deliverables that allows surreptitious unauthorized access to data.
CVE	means Common Vulnerabilities and Exposures as defined in: http://cve.mitre.org/index.html .
CVSS	means Common Vulnerability Scoring System as defined in http://www.first.org/cvss/ .
Defect	means any deviation of the actual quality of the Deliverable from the contractually intended quality, e.g. default, non-compliance of the Deliverables with their corresponding specification or their failure to perform in accordance with related documentation.
Deliverables	mean all equipment(s), product(s) and service(s) which are to be supplied, provided, performed and/or sold by the Supplier to TM pursuant to the Agreement including all main and ancillary obligations.
Hardware	Means any computer and related devices and equipment that includes but is not limited to any embedded software/firmware (e.g. end-user equipment and devices for Internet of Things, IT equipment, etc.;
Information Security	means – in compliance with ISO/IEC 27001 and ISO/IEC 27005 - security in the scope of information processing and activities (primary assets) relying on technical (including, but not limited to IT, premises, facilities, networks) and non-technical resources (including, but not limited to supporting assets such as staff, partners, organizations, procedures, terms and conditions).
Internet of Things	means any connected devices or equipment for internet of things
Official Fix	means that a complete Supplier solution is available to fix a Vulnerability, either by means of an official patch or an upgrade.
Professional Services	means any work(s) in performing installation, training, integration, maintenance and/or consulting.

Software	refers to off-the-shelf vendor software and/or custom software as specified and described in the Agreement and/or Statement of Work agreed by the Parties (such as but not limited to e.g. Software Result);
Software Result	means any software that is: (i) primarily based on and/or directed to the TM's requirements and/or specifications provided by or exclusively for TM; and/ or (ii) developed or implemented by Supplier under the Agreement (and/or any subsequent amendments), and which is not a background; which may or may not be protected by intellectual property rights, as well as any product or process resulting from it.
Statement of Compliance	means an exhibit of Agreement with detailed technical security requirements on Deliverables.
Statement of Work (SoW)	means a document defining project-specific activities, deliverables and timelines for the Supplier providing Deliverables and/or Services to TM.
Supplier	Refers to the service provider that provides the Deliverables to TM pursuant to the Agreement including all main and ancillary obligations.
Supplier Resources	means hardware, software belonging to and/or under liability of Supplier and used for the purpose of providing the Deliverables.
Temporary Fix	Includes but not limited to termination/isolation of vulnerable service, applying configuration changes, enforcing stricter network firewall policy, applying blocking signature at web application firewall and endpoint policies.
TM Network	means the network managed by TM and all related TM Network infrastructures.
TM Resources	means hardware, software, services belonging to TM and used for the purpose of providing the Deliverables.
Vulnerability	means a weakness that reduces availability, integrity or confidentiality.
XaaS	means anything delivered to users as a service including SaaS (Software as a Service), PaaS (Platform as a Service), IaaS (Infrastructure as a Service) or similar.
Zero-Day	means an undisclosed vulnerability that hackers can exploit to adversely affect Deliverables. It is known as a "zero-day" (or "zero-hour" or "0-day" or "day zero") because it is not publicly reported or announced before becoming active, leaving the Supplier with zero days in which to create patches or advise workarounds to mitigate its actions.

Acceptance of TM Information Security Annex (A):

Full name:

Designation:

Date:

Proposer's Seal or Stamp: